

# TianShanOS

## 安全页面完整操作指南

从首次设置到日常维护：操作步骤、结果确认与安全提醒

账号安全 · SSH 密钥 · 主机指纹 · HTTPS / mTLS · Config Pack

生成日期：2026-09-07

# 目录

---

|                         |    |
|-------------------------|----|
| 1. 开始前先确认               | 3  |
| 2. 修改设备登录密码             | 4  |
| 3. 用 SSH 密钥连接服务器        | 4  |
| 4. 管理密钥、主机与指纹           | 6  |
| 5. 配置 HTTPS 证书与 mTLS    | 8  |
| 6. 使用 Config Pack 前先看限制 | 9  |
| 7. 故障与安全事件处理            | 11 |
| 8. 核查依据与术语              | 12 |

这份指南帮助你修改设备密码、管理 SSH 连接，以及配置证书。第一次使用建议先读第 1、2 章；证书和配置包由负责设备安全的管理员处理。

适用版本：2026-09-07 核查的工作区代码，基线提交 [d6ed947](#)。结论来自代码检查，不代表已在你的设备上完成测试；每节的“确认结果”需要在实际环境中执行。

先确认网络安全：当前完整管理页面使用 HTTP，且多数接口没有统一执行登录和权限检查。请只在受控、隔离的管理网络中操作，不要将设备直接暴露到公网或访客网络。安装 HTTPS 证书不会把完整管理页面自动切换到 HTTPS。

## 1. 开始前先确认

### 1.1 找到你需要的功能

| 你要做什么              | 到哪里操作                         |
|--------------------|-------------------------------|
| 修改设备 root/admin 密码 | 账号安全，见第 2 章                   |
| 让设备用密钥连接服务器        | 密钥管理、已部署主机，见第 3 章             |
| 复制密钥、处理服务器身份变化     | 密钥管理、已知主机指纹，见第 4 章            |
| 配置设备证书和双向证书认证      | HTTPS 证书，见第 5 章               |
| 交换加密配置包            | Config Pack，见第 6 章；通用应用功能尚未完成 |

### 1.2 账号与设备身份不是一回事

- admin：能进入安全页，看到密钥、主机、证书和配置包功能，但看不到“账号安全”。
- root：还可以设置 root/admin 密码，或重置 admin 密码。这些密码管理接口会在后端校验 root 身份。
- Developer 设备：由设备证书的 OU 属性识别，不是登录账号。当前只有这类设备能导出配置包和 SSH 主机配置；以 root 登录不会改变设备身份。

除上述密码管理等自行校验身份的接口外，不能依靠“页面需要登录”阻止直接调用接口。网络隔离仍是当前使用前提。

### 1.3 操作前的准备

1. 确认地址栏 IP 对应目标设备，电脑也在可信管理网络中。
2. 向服务器管理员确认 SSH 地址、端口和用户名。
3. 使用页面部署或撤销公钥时，需要目标账户的密码，且该账户允许密码登录。不要为排障长期放宽服务器策略。

4. 删除密钥、撤销授权或更换证书前，确认还有服务器控制台、另一管理员密钥或设备 HTTP 管理入口可用。

## 2. 修改设备登录密码

---

这里修改的是 TianShanOS 的登录密码，不是远端服务器的 SSH 密码。

### 2.1 首次登录后的密码提醒

账号尚未标记为已修改密码时，登录后会出现改密提醒。请设置独有的长密码，不要选择“稍后修改”后长期保留默认密码。

这个提醒并不是随时可打开的账号设置入口。已经改过密码的 admin 用户如需再次改密，可由 root 在安全页设置。

### 2.2 由 root 设置密码

1. 以 root 登录，打开“安全”。
2. 在“账号安全”中点击“设置 root 密码”或“设置 admin 密码”。
3. 两次输入相同的新密码并提交。界面接受 4-64 个字符；4 个字符只是技术下限，不是强度建议。

确认结果：用无痕窗口重新登录，确认新密码可用，再关闭原会话。修改密码不会自动结束已有会话。

登录失败时：先核对账号和设备 IP。连续 5 次失败会锁定约 5 分钟，不要反复猜测。

### 2.3 重置 admin 密码

root 可在账号安全区将 admin 重置为默认密码 `rm01`，并清除 admin 的登录锁定。重置后，立即用新会话登录 admin 并设置新密码。

重置是临时恢复手段。不要把默认密码留作日常使用，也不要把“修改密码”理解为已踢出所有旧会话。

## 3. 用 SSH 密钥连接服务器

---

首次设置按以下顺序进行：生成 RSA 密钥 → 部署公钥 → 测试连接 → 核对服务器身份。退役时，先撤销远端授权，确认不能再登录，最后删除本地密钥。

### 3.1 生成密钥

1. 在“密钥管理”中点击“生成新密钥”。

2. 先查看已有列表，再输入未使用的密钥 ID，例如 `backup01`。不要复用旧 ID：当前生成接口没有重复 ID 拦截，可能覆盖原密钥。
3. 选择 RSA 2048 或 RSA 4096。页面默认选 RSA 2048；虽然也列出 ECDSA，但当前 SSH 公钥认证不支持它。
4. 按需填写备注和别名。只有确实需要备份或迁移私钥时，才勾选“允许导出私钥”；生成后没有修改此属性的页面入口。
5. 点击“生成”，完成后刷新列表。

确认结果：找到正确的 ID 和 RSA 类型，点击“公钥”，确认完整文本以 `ssh-rsa` 开头。

注意：密钥列表容量为 8 个。满额时不要继续生成；先按撤销流程清理旧密钥。当前保存与列表登记并非完整的原子操作，成功提示后也要检查列表。“隐藏密钥 ID”不能保护真实 ID 不被接口读取。

### 3.2 部署公钥

部署会将公钥追加到远端账户的 `~/.ssh/authorized_keys`，使设备有机会用对应私钥登录。它不会修改服务器密码。

1. 在新密钥所在行点击“部署”。
2. 填写服务器地址、用户名、SSH 端口和该账户的密码。
3. 核对信息，点击“开始部署”。
4. 完成后，在“已部署主机”检查对应记录，并按下一节测试。

当前流程先用密码完成 SSH 认证，再检查主机指纹；首次遇到的主机会被自动信任。它不能保证“确认服务器身份后才发送密码”。首次连接必须在受控网络中进行，事后比对指纹不能消除密码已经发出的风险。

提示成功但列表没有记录，或测试失败时：不要马上重复部署。远端公钥可能已经写入，只是密钥登录复验或本地保存失败。请从另一管理入口检查 `authorized_keys`；反复部署可能追加重复行。

### 3.3 测试连接并确认结果

1. 在“已部署主机”核对地址、端口、用户名和密钥 ID。
2. 点击“测试”。设备会尝试执行固定命令 `echo "TianshanOS SSH Test OK"`。
3. 首次连接后，按第 4.3 节核对保存的主机指纹。

如何理解成功提示：页面只检查 API 请求是否成功，没有检查远端命令的退出码和回显内容。因此它是基础连接检查，不是完整验收，更不能证明 `sudo` 或业务命令可用。重要用途还需在实际任务中确认命令输出、退出码和权限。

测试失败时：先检查网络、SSH 服务、账户与远端授权。涉及指纹变化或服务器身份不明时，停止重试，按第 4.3 节处理。

### 3.4 撤销远端授权，再删除本地密钥

- 1. 确认另一条服务器管理入口可用，且设备上的原密钥尚未删除。
- 2. 在“已部署主机”对应行点击“撤销”，输入服务器密码，确认“撤销并移除”。也可从密钥行发起撤销并填写目标信息。
- 3. 查看撤销结果，再从可信的服务器管理入口检查 `authorized_keys`，确认对应公钥及重复行已移除。
- 4. 确认旧密钥不能再登录。撤销会留下 `authorized_keys.bak` 备份；按服务器备份策略处理，避免以后恢复旧授权。
- 5. 刷新本地主机列表。页面会尝试移除记录，但没有核对该移除请求的结果，必要时再手动“移除”。
- 6. 所有目标服务器都处理完后，才删除设备中的旧密钥及不再需要的私钥副本。

提示“未找到公钥”：先从服务器侧确认选对账户且公钥确实不存在，再选择仅移除本地记录。

撤销失败或服务器身份可疑：保留本地密钥，改用可信控制台或另一管理员入口处理。不要继续向可疑服务器发送密码。

## 4. 管理密钥、主机与指纹

### 4.1 复制公钥和导出私钥

公钥：点击密钥行的“公钥”，复制完整的一行给服务器管理员。公钥不是秘密；发错对象本身不等于私钥泄露，也不要求立即换钥。管理员必须另行把它加入授权列表，才会产生访问权限。

私钥：只有生成时允许导出的密钥才能点击“私钥”导出。请在可信电脑和隔离网络中操作，保存到受控密钥库，并清理剪贴板、下载目录等临时副本。不要粘贴到聊天、工单或日志里。

复制按钮无响应：HTTP 页面可能无法使用浏览器剪贴板接口。可手动选中并复制可见文本，随后检查开头、结尾和内容是否完整。不要为方便复制而放宽浏览器安全设置。

### 4.2 分清“撤销”“移除”和“删除”

| 操作       | 改变什么                         |
|----------|------------------------------|
| 撤销公钥     | 尝试删除服务器上的授权，需要远端密码           |
| 移除主机     | 删除设备本地的连接记录，不撤销服务器授权         |
| 删除密钥     | 删除设备本地密钥，不访问服务器，也不撤销授权       |
| 删除已知主机指纹 | 删除设备保存的服务器身份记录，不删除连接记录或服务器授权 |

“已部署主机”是本地清单，不会持续查询服务器。列表为空不代表远端授权已清理；列表中有记录也不代表现在仍能登录。

### 4.3 核对 SSH 服务器指纹

指纹用于确认你连接的是哪台服务器。当前页面保存 SHA-256 摘要的 64 位十六进制值；常见 OpenSSH 输出则是 `SHA256:base64`。先请管理员统一格式，不能直接比较这两种字符串。

首次连接后：在“已知主机指纹”点击“查看”，与服务器控制台、资产系统或另一条可信渠道提供的完整值比较。表格只显示前 32 位，不足以完成核对。

不一致时：停止连接并隔离调查。若已输入 SSH 密码，按可能泄露处理，通过可信入口修改密码、检查登录日志和清理不应存在的公钥。不要通过可疑连接执行页面撤销。

已保存的指纹发生变化时：

1. 暂停重试，不要直接删除旧记录。
2. 通过可信控制台核对新指纹、IP、端口、资产身份和维护记录。
3. 只有确认是服务器重装或正常换钥后，才删除旧指纹。
4. 在受控网络重新连接，再次查看并核对新记录。

页面当前可能只显示通用连接错误，不一定出现专门的指纹对比弹窗。

保管 SD 卡：指纹会保存到设备存储，并同步为 SD 卡明文 JSON。启动时有 SD 指纹配置就会以它为准替换对应 NVS 记录；文件没有签名保护。不要让不可信人员修改 SD 卡。

### 4.4 导入和导出 SSH 主机配置

这是一条专用的 `.tscfg` 流程，与第 6 章尚未完成的通用配置应用不同。包中保存主机地址、端口、用户、认证类型和密钥 ID，不包含 SSH 密码或私钥，也不授予远端权限。

导出：在 Developer 设备上点击主机行“导出”，给另一设备使用时提供并核对目标设备证书，然后下载包。普通设备即使能看到按钮，后端也会拒绝导出。

导入：

1. 确认包是为本设备制作的，SD 卡可写，并通过可信渠道核对来源。
2. 确认本设备已有包所引用的正确密钥。只有相同 ID 不够，密钥本身也必须与服务器授权对应。
3. 点击主机配置导入入口，选择文件并检查预览。只有确实要替换同名配置时才勾选覆盖。
4. 确认后按提示重启。导入只把包保存到 SD 卡，重启时才尝试加载和解密。
5. 检查加载后的地址、用户、端口和密钥 ID，再测试连接。

预览通过不等于可用：它既没有确认签名者可信，也没有核对接收设备指纹；目标检查要到重启加载时才执行。错误记录需要移除，并清理 SD 卡中对应包，避免重启后重新加载。更换设备证书前请同时阅读第 5.5 节。

## 5. 配置 HTTPS 证书与 mTLS

这部分面向证书管理员。当前 443 服务只提供健康、身份和权限测试接口，不提供完整管理页面。默认启动还需要设备私钥、设备证书和客户端 CA 链齐备。

### 5.1 先分清证书方向

- 设备私钥和设备证书：让设备向连接它的客户端证明身份。
- 客户端证书和私钥：由电脑或服务持有，让客户端向设备证明身份。
- 安装在设备上的 CA 链：用于验证客户端证书，不会自动让电脑或浏览器信任设备证书。

双方都出示证书的方式叫 mTLS。客户端侧仍需配置信任设备证书的 CA，并校验访问名称和证书用途。

### 5.2 生成设备私钥和证书申请

1. 在“HTTPS 证书”点击“生成密钥对”。这会生成独立的 ECDSA P-256 私钥，与 SSH 密钥无关；本界面不能导出它。
2. 已有私钥时先停止，按第 5.5 节确认替换影响；继续生成会覆盖旧私钥。
3. 点击“生成 CSR”，填写设备 ID (CN)、组织 (O) 和组织单位 (OU)，或全部留空。
4. 复制完整的 CSR 文本给 CA 管理员。CSR 是证书申请，不含私钥，也不会自动安装证书。

签发前必须检查名称：自定义字段路径不会生成 SAN；全部留空时，CN 固定为 `TIANSHAN-DEVICE-001`，仅在能取得当前 IP 时加入该 IP 的 SAN，不含 DNS SAN。请让 CA 管理员核对 CSR，并通过受控签发流程把实际访问的 IP/DNS 加入最终证书 SAN；此表单不能编辑 SAN。

确认结果：刷新后确认私钥存在；让 CA 管理员解析 CSR，核对公钥、主体和 SAN，并确认最终证书包含所需的服务器认证用途 (EKU)。

### 5.3 安装设备证书

1. 取得与当前设备私钥匹配的 PEM 证书。
2. 点击“安装证书”，粘贴包含首尾标记的完整文本并提交。
3. 查看证书，核对主体、签发者和有效期。

成功提示只表示：证书可以解析，且公钥与当前私钥匹配。安装过程没有完整验证信任链、SAN、EKU、当前有效期或主体策略。

最终是否可信，要由实际客户端检查证书链、访问地址、用途和有效期。若提示密钥不匹配，先找回当前 CSR 对应的证书，不要为了消除错误而重新生成私钥。

## 5.4 安装客户端 CA 链并测试

1. 点击“安装 CA”，粘贴用于信任客户端证书的一个或多个 PEM CA 证书。
2. 保留 HTTP 管理入口，安排重启设备后再测试。安装接口只更新存储，不会主动重启正在运行的 443 服务。
3. 使用受信任、用途及角色正确的客户端证书访问相应测试端点。
4. 再使用不受信任的证书或不提供证书测试，确认连接被拒绝。

**确认结果：**设备使用预期的新证书；可信客户端只能访问其角色允许的接口，不可信客户端无法接入。具体握手和角色行为需要真机验收，不能仅凭安装提示确认。

## 5.5 更新证书或删除全部凭证

**仅证书到期：**可以沿用未泄露的私钥申请新证书，安装后重新测试。但配置包绑定的是接收方证书指纹；即使沿用同一私钥，新证书指纹改变后，重新初始化或重启加载的旧包也会因目标不匹配而被拒绝。更换前请重新制作需要保留的包。

**替换私钥：**旧证书和旧 CSR 不再对应新私钥。这不等于旧证书已被 CA 吊销；若旧私钥泄露，应另行执行吊销和事件处理。没有旧私钥时，依赖它的旧包可能无法恢复。

**删除全部 PKI 凭证：**证书区的“删除凭证”会一起清除设备私钥、设备证书和客户端 CA 链。先确认 HTTP 管理入口可用，完成配置包替代安排，再确认删除。公开证书备份不能恢复私钥。

删除后刷新应显示未初始化；重启后检查 443 不再使用旧凭证。重新启用时需重新生成私钥、签发设备证书、安装 CA 链并完成测试。

## 6. 使用 Config Pack 前先看限制

Config Pack 是加密、签名的 `.tscfg` 配置包。当前可以生成和检查包，但通用配置应用尚未完成，不要将它用于生产批量配置、灾难恢复或证明配置已经生效。

### 6.1 各按钮目前实际做什么

| 操作              | 当前结果                            |
|-----------------|---------------------------------|
| 导出设备证书          | 显示公开证书，供发送方为本设备制作包；不导出私钥        |
| 验证              | 检查包结构和自带证书对应的密文签名，不确认签名者可信或目标匹配 |
| 安全页选择/粘贴包后导入    | 前后端参数不匹配，当前不能完成导入               |
| 配置包列表中的导入       | 验证设备上已有文件，不复制、不解密、不应用           |
| 应用              | 解密并列出模块名，但没有写入模块配置；仍可能提示成功      |
| Developer 导出配置包 | 生成可下载的加密签名包，并尝试保存到 SD 卡         |

## 6.2 核对来源，不要只看“签名有效”

接收设备目前用包内自带的证书检查签名，没有完成签名者证书链信任验证。签名保护的是包内密文，不应由此推断所有展示字段都已得到可信认证。“官方”字段也不能作为来源证明。

导入或检查前，通过资产系统或管理员认可的独立渠道核对签名者证书指纹、目标设备证书和包的用途。不要只凭同一封邮件同时收到的证书和指纹判断可信；预览里的目标名称也不能替代证书指纹核对。

## 6.3 导出设备证书、检查收到的包

**提供本设备证书：**点击“导出设备证书”，复制完整 PEM 和显示的指纹，将公开证书交给发送方，再通过独立可信渠道核对指纹。

**检查收到的包：**打开“导入配置包”，选择或粘贴 `.tscfg`，点击“验证”。检查签名者信息并核对来源；验证不会应用配置，也不会证明包属于本设备。来源不明、目标不符或用途不清时停止。

即使验证通过，也不要继续依赖当前通用“导入”和“应用”完成配置。请回到对应功能页面使用已支持的设置方式，并检查实际结果。

## 6.4 Developer 设备导出配置包

1. 准备 SD 卡中的有效 JSON 配置文件，并取得已核对的目标设备证书。
2. 点击“导出配置包”，选择文件，填写名称和说明，粘贴目标证书。
3. 生成后下载 `.tscfg`。
4. 分别检查浏览器下载文件和设备上的 `/sdcard/output_config/` 保存结果。SD 保存失败时，接口仍可能返回包内容供下载。

导出不会修改源配置。发送给错误目标或接收方证书已更换时，需要重新生成包。当前接收端的通用应用功能仍未完成，不能因为导出成功就认为整个分发流程可用。

## 7. 故障与安全事件处理

### 7.1 常见问题

| 现象            | 处理方式                                     |
|---------------|------------------------------------------|
| 看不到账号安全       | 用 root 登录；admin 不显示此区块                   |
| 密钥生成成功但找不到    | 刷新列表并检查容量；不要复用 ID 或反复生成                  |
| ECDSA 部署失败    | 改用新 ID 生成 RSA 密钥；不要反复放宽服务器策略             |
| 部署成功但测试失败     | 从另一入口检查远端授权；不要直接重复部署                     |
| 移除主机后仍能登录     | 移除仅清理本地记录，需另行撤销远端公钥                      |
| 指纹变化或主机身份不明   | 停止连接，通过可信控制台核对，见第 4.3 节                  |
| 安装证书后 443 不可用 | 检查私钥、设备证书、客户端 CA 链是否齐备，重启后用正确客户端证书测试     |
| 客户端仍报证书不可信    | 检查客户端信任库、SAN、EKU、有效期及证书链；设备内 CA 不是浏览器信任库 |
| 配置包应用成功但配置没变  | 当前实现没有写入模块配置，回到各功能页面操作                   |

### 7.2 SSH 私钥可能泄露

1. 限制设备和日志访问；当前日志可能包含私钥开头片段。
2. 通过可信入口逐台撤销远端公钥，核对备份副本，确认旧密钥不能登录。
3. 用新 ID 生成 RSA 密钥并重新部署，确认正常后删除旧密钥和导出副本。
4. 检查相关登录日志。设备本地列表不一定覆盖所有曾授权的服务器。

如果泄露的是 HTTPS 私钥，按第 5.5 节替换设备凭证，并与 CA 管理员处理旧证书吊销及旧配置包。

### 7.3 当前版本还需承担的风险

除前述 HTTP、接口鉴权、首次主机信任及配置包限制外，当前检查的构建配置未启用 NVS Encryption、Flash Encryption 和 Secure Boot。不能宣称设备私钥已得到这些存储和启动保护；实际设备的烧录配置与 eFuse 状态还需另行核验。

如使用场景无法接受这些限制，应暂停接入相应网络，由安全负责人决定隔离措施或产品修复。不要用操作手册中的验证步骤替代缺失的产品安全控制。

## 8. 核查依据与术语

---

### 8.1 本次如何核查

本指南对照了 d6ed947 基线下的当前工作区：页面操作和提示位于

`components/ts_webui/web/js/app.js`；API 行为位于 `components/ts_api/src/`；密钥与主机存储位于 `components/ts_security/src/`；证书、443 服务及配置包分别位于 `components/ts_cert/`、`components/ts_https/` 和 `components/ts_config_pack/`。

重点复查了重复密钥 ID、测试退出码、撤销后的本地清理、证书指纹绑定，以及配置包未完成的导入/应用逻辑。这是静态代码核查；没有在本轮修改中连接远端服务器、变更设备凭证或进行真机安全验收。

### 8.2 常用术语

- 公钥 / 私钥：公钥可交给授权方；私钥必须保密。服务器授权的是公钥，设备登录时使用对应私钥。
- NVS：设备 Flash 中保存设置和密钥的存储区域；这个名称本身不表示数据已加密。
- CSR / CA：CSR 是证书申请；CA 是签发或验证证书的机构或相应证书。
- CN / O / OU：证书主体中的通用名、组织和组织单位。
- SAN / EKU：分别说明证书可用于哪些访问名称或 IP，以及哪些认证用途。
- PEM：带有 BEGIN/END 标记的文本格式，可用于证书、CSR 和密钥。
- PKI / mTLS：PKI 是证书及信任管理体系；mTLS 是客户端和服务端双方都出示证书的连接方式。